

Лабораторна робота 13. Звіт пентесту за PTES-стандартом

Останній артефакт. Те, що клієнт реально читає.

Факультет комп'ютерних технологій та кібербезпеки • Весна 2026

Тривалість:	Самостійна робота протягом тижня, орієнтовно від шести до восьми годин
Всього:	100 балів. З них Трек А становить 75 балів і Трек В становить 25 балів
Вихідний матеріал (Трек А):	Одна з ваших завершених лабораторних, а саме Лабораторна 7, Лабораторна 8 чи Лабораторна 9, за вашим вибором
Тип роботи:	Перетворення технічної роботи у клієнтський звіт за стандартом PTES

ЯК ПРАЦЮЄ ЦЯ ЛАБОРАТОРНА РОБОТА

Структура цієї лабораторної роботи принципово відрізняється від попередніх дванадцяти. Тут не буде роботи з Nmap. Експлойти, на які ми спиралися протягом усього семестру, цього разу залишаються поза увагою. Не буде і традиційного отримання шеллу. Уся робота сконцентрована навколо одного артефакту, а саме навколо звіту пентесту, що згодом буде передано уявному, а в перспективі цілком реальному клієнтові. Цей звіт є тим документом, на підставі якого CISO формуватиме свою позицію перед радою директорів. У разі звернення з боку регулятора юридичний відділ компанії посилатиметься саме на нього. Що ж до вас особисто, то цей звіт ви, ймовірно, покажете на першій же серйозній співбесіді у галузі.

Виберіть одну з ваших завершених лабораторних робіт. Це може бути Лабораторна 7, у якій ви працювали з Metasploit проти Mr-Robot 1. Можливим джерелом є Лабораторна 8, присвячена атакам на паролі. Виправданим вибором буде і Лабораторна 9 з підвищенням привілеїв. Будь-який із цих трьох варіантів стає вашим пентест-проектом, тобто тією технічною роботою, яку вам тепер належить перепакувати у формат клієнтської поставки. Якщо ви виконували Лабораторну 9 у повному обсязі і брали Трек В з машиною Kioptrix Level 1.2, тоді є сенс включити цю частину як другий етап того самого engagement-у. Звіт від цього лише виграє, оскільки отримає багатшу історію атаки і складнішу архітектуру викладення.

Трек А складається з шести частин і оцінюється загалом на 75 балів. Структурно він являє собою повний звіт за стандартом PTES, починаючи з обкладинки і завершуючи додатками. Подробиці я подаю в окремій таблиці нижче. За моїм досвідом якісно виконаний Трек А еквівалентний оцінці в діапазоні від B+ до A-.

Трек В становить додаткову роботу обсягом у 25 балів. Йдеться про Remediation Roadmap, тобто про додаток до основного звіту, у якому ваші знахідки перетворюються на конкретний план виконання для клієнта. Тут уже звіт говорить мовою CIO, а не лише CISO. Структуру цього додатка я детально подаю у частині 7. Саме він відрізняє звіт junior-пентестера від звіту, який реально допомагає клієнтові планувати інвестиції в безпеку.

Трек В оцінюється тільки за умови якісного виконання Треку А. Якщо Трек А набирає менше ніж 50 балів зі 75, роботу Треку В буде проігноровано. Це не покарання у виховному сенсі. Це наслідок логіки документа. Якщо основний звіт слабкий, додаток до нього не має своєї аудиторії.

ОБОВ'ЯЗКОВІ ПРАВИЛА ЗВІТУВАННЯ

Звіт із копіастом ваших попередніх робіт отримає 0 балів. Дозвольте пояснити, чому я ставлюся до цього питання настільки жорстко. Попередні лабораторні роботи були вправами у дидактичному сенсі. Ви демонстрували викладачеві те, що ви думаєте і що ви знаєте. Цей звіт належить до іншого жанру. Він є deliverable, тобто окремим документом, що пишеться з нуля у форматі клієнтської поставки. Аудиторія тут не я.

Кожна знахідка повинна мати розширену анатомію звіту. Вона базується на структурі з Лекції 10, але для повноцінного клієнтського PTES-звіту деталізується до восьми обов'язкових полів. У разі відсутності хоча б одного з полів знахідка оцінюється у половину можливих балів за неї. Перелік полів і вимоги до кожного я подаю окремою таблицею у Частині 4. Раджу проглянути цю таблицю ще до початку роботи над знахідками, щоб мати повне уявлення про обсяг роботи.

Виконавче резюме не повинно перевищувати 1 сторінку. Це жорстка межа, а не побажання. Усередині резюме не може бути CVE-номерів. Технічний жаргон, якщо вже з'являється, потребує негайного пояснення одразу в тексті. Скріншоти на цій сторінці категорично заборонені. CISO має зрозуміти текст за дві хвилини читання. Якщо уявний CFO не зрозуміє хоча б одного абзацу, резюме потрібно переписувати.

Звіт має містити докази вашої власної ітерації. Це специфічна вимога, і вона потребує пояснення. У реальному пентест-звіті завжди є слід чорнової роботи. Перша оцінка CVSS майже ніколи не збігається з фінальною. Перший варіант executive summary зазвичай переписують два чи три рази. Я розраховую побачити цей слід у вашому звіті. Тому в одному з додатків покажіть, як один із ключових елементів звіту змінювався у процесі ваших розмірковувань. Без слідів ітерації документ виглядає так, наче його було згенеровано одним натисканням клавіші. У певному сенсі саме у цьому й полягає проблема.

Звіт має посилаватися на ваші власні артефакти. Маю на увазі команди, які ви реально запускали, з точними прапорцями. Маю на увазі timestamps, що з'являлися на екрані у момент роботи. Сюди ж належать значення хешів, які ви бачили у виводі John the Ripper. IP-адреса цільової машини у вашому конкретному середовищі також належить до вашого запуску. Те саме стосується версії сервісу, яку Nmap повернув у виводі. Обсяг виводу від find / -perm -4000, тобто скільки рядків ви насправді отримали, належить тільки вашій сесії. Загальні фрази на кшталт «system has SUID misconfigurations» отримують половину балів за відповідну знахідку. Конкретний опис із

посиланнями на власні артефакти отримує повний бал. Звіти, у яких знахідки описано шаблонними формулюваннями без прив'язки до власного запуску, отримують нуль балів за відповідну частину незалежно від обсягу тексту. Винятків тут немає.

Сценарій

Уявіть таку ситуацію. Минуло два тижні після завершення вашого engagement-у. У понеділок вранці на вашу пошту надходить лист від CISO компанії-клієнта. Лист короткий, наводжу його повністю. «Дякую за технічну роботу. Тепер потрібен фінальний звіт для нашої ради директорів, оскільки її засідання вже наступної п'ятниці. CFO нервує. Юридичний відділ хоче бачити severity з обґрунтуванням. ESG-комітет, який ми створили минулого року, питає про governance impact. Формат PTES, обсяг від дванадцяти до вісімнадцяти сторінок, дедлайн у п'ятницю о шістнадцятій годині.»

Це найчастіший формат постengagement-комунікації, з яким ви зустрінетеся у професії. Технічна робота позаду. Залишається найскладніший крок, тобто переклад того, що ви зробили, мовою людей, які ухвалюють рішення щодо бюджету. У моєму досвіді саме на цьому етапі більшість junior-пентестерів програють контракт. Технічно вони можуть бути блискучими фахівцями, проте звіт не читається аудиторією замовника. Я бачила випадки, у яких клієнт відмовлявся приймати добре виконану технічну роботу лише через те, що звіт неможливо було показати раді директорів. Це непросте усвідомлення, проте воно є частиною професії, з якою доведеться навчитися працювати.

Ваше завдання сформульовано так. Перетворити роботу однієї з ваших завершених лабораторних, а саме Лабораторної 7, Лабораторної 8 чи Лабораторної 9 за вашим власним вибором, у повноцінний PTES-звіт обсягом від 12 до 18 сторінок без додатків, готовий до передачі клієнтові. Це не reformatting вашого попереднього попереднього звіту. Це переписування з нуля з огляду на іншу аудиторію. Ваш попередній submission був написаний для викладача. Цей звіт пишеться для іншої аудиторії. Серед її читачів буде CISO, до якого ви, ймовірно, певною мірою вже звикли. Поряд із ним документ читатиме CFO, а це вже зовсім інша професійна перспектива. Юридичний відділ також буде серед адресатів, і у нього свої вимоги до формулювань.

Окремо слід зупинитися на виборі клієнта у звіті. Якщо ви обрали Лабораторну 7, тобто роботу з Mr-Robot 1, у звіті називайте клієнта E Corp Information Security. Якщо вашим джерелом є Лабораторна 8 або Лабораторна 9, які працювали з Metasploitable 2 з опційним додаванням Kioptrix Level 1.2, клієнтом у звіті є Cassandra Pay. Це ті самі компанії, які фігурували в оригінальних сценаріях відповідних лабораторних, тож контекст у вас уже сформований. Якщо ви додаєте Kioptrix Level 1.2 з Треку B Лабораторної 9, тоді цю роботу слід оформити як другий етап того самого контракту з Cassandra Pay. Сценарно це можна обґрунтувати тим, що компанія попросила оцінити одну VM, отриману від кандидата на тендер на постачання інфраструктури.

Структура роботи

Звіт повинен містити шість основних розділів у Треку А і опціональний сьомий розділ у Треку В. Орієнтовний розподіл балів і обсягу подано у таблиці нижче. Звертаю увагу, що обсяг є орієнтиром, а не жорсткою вимогою з точністю до однієї сторінки. Головна вимога — не кількість сторінок сама по собі, а повнота доказів, коректність severity та здатність пояснити бізнес-ризик.

№	Опис	Трек	Бали	Обсяг
1	Cover page, метадані, зміст	A	5	1 стор.
2	Виконавче резюме	A	15	1 стор.
3	Engagement Overview (scope, ROE, methodology)	A	10	2-3 стор.
4	Технічні знахідки (мінімум 4)	A	30	5-8 стор.
5	Зведена таблиця рекомендацій	A	10	1-2 стор.
6	Додатки і докази ітерації	A	5	2-3 стор.
7	Remediation Roadmap (priority + cost + 30/60/90)	B	25	3-5 стор.

Частина 1. Cover page, метадані, зміст

(5 балів. Трек А)

Перший розділ звіту присвячений тому, що зчитується раніше за решту тексту, а саме: обкладинці, метаданим документа і змісту. Це не формальність. У моїй практиці перша сторінка звіту визначає, з якою інтонацією клієнт читатиме все інше. Якщо обкладинка виглядає як скан студентського конспекту, далі звіт уже не оцінюється всерйоз, навіть якщо технічна частина бездоганна.

Завдання 1.1. Cover page (2 бали)

Перша сторінка звіту фактично є окремим документом. Її прочитають усі. Більшість прочитає тільки її. Cover page має містити назву документа у формі «Penetration Testing Report» або, у випадку україномовного звіту, «Звіт пентесту». Сюди ж входить назва клієнта. Це або E Corp Information Security, або Cassandra Pay, залежно від того, яку лабораторну ви обрали як джерело. Окремо наводиться назва engagement-у з зазначенням типу тесту та об'єкта, наприклад, «External Black-box Assessment of Production Server». Номер версії документа для першого фінального варіанту дорівнює 1.0. Поряд із цим обов'язково зазначається дата публікації. Ваше ім'я зазначається як автор. Класифікація документа також зазначена на обкладинці, і в нашому випадку вона має бути CONFIDENTIAL або у форматі TLP:AMBER. Двох-трьох логотипів буде достатньо. Оскільки ваша фірма уявна, замість реальних логотипів, припустимо, використайте плейсхолдери. Жодної технічної інформації на цій сторінці не повинно бути. CVE-номерам на обкладинці не місце. IP-адресам теж. Будь-яке severity-маркування також не має бути на першій сторінці. Це обкладинка.

Завдання 1.2. Метадані звіту (2 бали)

Друга сторінка є таблицею метаданих, яка стане у нагоді при кожному перевипуску документа. Вона має містити версію документа і журнал змін, у якому має бути щонайменше один рядок виду «1.0, Initial Release, ваше ім'я, дата». Сюди ж входить distribution list, тобто перелік осіб, яким передається документ. До цього списку зазвичай входить CISO як основний адресат. Поряд із ним документ читатиме CIO. CFO теж входить до числа адресатів, особливо у тих випадках, коли звіт прямо впливає на бюджетні рішення. Представник внутрішнього аудиту за замовчуванням потрапляє до distribution list. Зовнішній аудитор додається до списку за наявності відповідної угоди з клієнтом. На цій же сторінці слід розмістити твердження щодо класифікації документа і обмежень на його поширення. Контактна інформація автора, тобто email вашої уявної фірми, теж має бути на сторінці метаданих, інакше клієнт не знатиме, до кого звертатися із запитаннями.

Завдання 1.3. Зміст (1 бал)

Третя сторінка є автоматично згенерованим Table of Contents у Word. Усі розділи звіту повинні мати правильну ієрархію Heading 1, Heading 2, Heading 3. Якщо ToC у вас не оновлюється автоматично, це означає, що ви не використали стилі заголовків. Це частина оцінки у цьому завданні, оскільки автоматизований зміст є показником професійної дисципліни роботи з Word.

Частина 2. Виконавче резюме

(15 балів. Трек А)

Виконавче резюме є окремим мікродокументом усередині звіту. Обсяг його становить рівно одну сторінку. Воно пишеться для людей, які не читатимуть нічого, крім самої цієї сторінки. Якщо CISO забере зі звіту одну сторінку й покаже її раді директорів, то це має бути ваша Executive Summary. Структурно резюме складається з 4 абзаців. Не маркований список, не таблиця. Чотири абзаци, кожен з яких виконує конкретну функцію у документі.

Завдання 2.1. Контекст engagement-у (4 бали)

Перший абзац обсягом три-чотири речення. Тут йдеться про те, що тестувалося, коли, чому і з якими обмеженнями. Без жаргону. Орієнтовний тон може бути таким. «У період з 12 по 26 квітня 2026 року компанія провела зовнішній penetration test одного production-сервера платформи обробки платежів Cassandra Pay. Тест проводився у форматі black-box з обмеженням на kernel-експлойти і pivot на сусідні системи. Метою тестування було визначення глибини потенційного ураження після первинної компрометації.» Цей абзац задає рамку для всього іншого тексту резюме.

Завдання 2.2. Загальний висновок з обґрунтуванням (3 бали)

Другий абзац обсягом у два-три речення. Перше речення подає загальну оцінку. Наприклад, так. «Безпека production-сервера оцінюється як НИЗЬКА через поєднання слабких облікових даних адміністративного облікового запису та misconfiguration-ів привілейованого доступу.» Друге речення називає найважливіший фактор, що формує цю оцінку. Третє речення, опціональне,

посилається на найкритичнішу знахідку. Без CVE-номерів, без числових значень CVSS. Прозою, як у короткому есе.

Завдання 2.3. Топ-3 ризики (5 балів)

Третій елемент резюме являє собою не абзац, а коротку таблицю з трьома рядками. Колонки таблиці такі. Перша колонка це назва ризику, сформульована мовою, зрозумілою нетехнічній людині. Друга колонка містить severity у категорійній формі, тобто оцінку за стандартними рівнями ризику. Третя колонка пояснює, що цей ризик означає для бізнесу, обсягом одне речення, без жаргону. Орієнтовний рядок виглядає так. «Слабкі облікові дані адміністратора | High | Зловмисник з мережі здатен отримати повний контроль над платіжним сервером менш ніж за чотири хвилини, що призведе до зупинки обробки платежів і можливої компрометації даних клієнтів.» Прошу звернути увагу на те, що у цій таблиці немає CVE-номерів. Немає вектора CVSS у його технічному вигляді. Технічних деталей у тексті топ-3 теж не повинно бути.

Топ-3 ранжуються за бізнес-ризиком, а не за CVSS. Знахідка з CVSS 9.8, що має низький бізнес-вплив, може опинитися нижче за знахідку з CVSS 7.2, що безпосередньо впливає на обробку платежів. У моєму досвіді саме у цій точці найчастіше плутаються junior-пентестери. Вони сортують топ-3 за технічною серйозністю, тоді як CISO потрібне сортування за впливом на бізнес.

Завдання 2.4. Найголовніша рекомендація (3 бали)

Четвертий абзац обсягом у два-три речення. Тут має з'явитися одна конкретна, адресна, коротка рекомендація, тобто те, що клієнт повинен зробити, перш ніж усе інше. Не «implement defence in depth». Конкретно так. «Першочергова рекомендація полягає у впровадженні обов'язкової зміни стандартних паролів адміністративних облікових записів протягом семи днів і у введенні політики складності паролів з мінімумом у чотирнадцять символів і заборонаю словникових слів. Це одна зміна, що виключає атаківий вектор, який використовувався у тесті, і яка не вимагає інфраструктурних змін.» Саме цю рекомендацію CISO покаже на нараді ради директорів. Формулюйте відповідно до цієї перспективи.

Частина 3. Engagement Overview

(10 балів. Трек А)

Цей розділ є фундаментом під технічну частину звіту. Тут ви закріплюєте, що було і що НЕ було у score. Без чіткого score-розділу будь-яка ваша знахідка може бути оскаржена клієнтом. Найчастіше така ситуація формулюється коротко, у дусі «ми вас цього робити не просили». Уникнути такого сценарію можна лише попереднім письмовим закріпленням меж тестування.

Завдання 3.1. Scope and Boundaries (3 бали)

Опис scope engagement-у має бути сформульованим явно. Цільова система описується конкретно. Йдеться передусім про IP-адресу машини. Hostname теж входить у цей опис як стандартний ідентифікатор. Service-tier має бути зафіксований у формі production, staging чи dev, з відповідним

обґрунтуванням у разі неочевидного вибору. Цільові сервіси документуються окремим переліком. У разі вибору Лабораторної 7 чи Лабораторної 8 серед цільових сервісів фігуруватиме SSH як основний вектор. У випадку Лабораторної 9 з Треком В до score додається HTTP як вектор первинної компрометації Kioptrix Level 1.2. Часове вікно тесту і перелік явних винятків так само мають бути присутніми. Винятки слід розписати уважно. Kernel-експлойти зазвичай належать до винятків для пентесту інфраструктурного типу через ризик нестабільності експлуатації. Так само denial-of-service не входить у score з міркувань стабільності production-середовища. Social engineering на співробітників, як правило, до score не входить, якщо тільки engagement не позиціонується як red team. Pivot на сусідні системи виключається з тих самих міркувань стабільності. Якщо ваше джерело Лабораторна 9, score включає Metasploitable 2 на конкретній IP-адресі, без kernel-експлойтів і без pivot. У разі додавання Лабораторної 9 Трек В окремий блок присвячується Kioptrix Level 1.2 як другому етапу engagement-у.

Завдання 3.2. Rules of Engagement summary (3 бали)

Коротке резюме ROE обсягом три-чотири речення. Сюди входить інформація про робочі години тесту. Окремо вказується контактна особа з боку клієнта на випадок інциденту. Заборонені дії описуються явно. У типовому випадку йдеться про заборону видалення даних. Сюди ж належить заборона зміни конфігурації цільових систем без попередження клієнта. Процедура escalation окреслюється коротко, з вказанням, кому і за яких умов треба телефонувати. Якщо ROE-документ існує окремо, посилайтеся на нього і підсумовуйте ключові пункти. У реальному engagement-і ROE підписується перед першим скануванням. У звіті ви фіксуєте те, що тест проходив у його межах. Це юридично значущий момент, який часто недооцінюють.

Завдання 3.3. Methodology за PTES-фазами (4 бали)

У цьому підрозділі покажіть, що ваш тест відповідав PTES-методології. Не переписуйте PTES повністю, посилайтеся на нього. Структура має бути такою. Спочатку коротко окресліть фазову структуру PTES. Стандарт визначає сім фаз. Починається все з Pre-engagement Interactions, тобто з юридичної і організаційної підготовки до тесту. За нею йде Intelligence Gathering, на якій ви, серед іншого, виконуєте OSINT. Threat Modeling зазвичай вважається опціональною для невеликих engagement-ів. Vulnerability Analysis і Exploitation утворюють серцевину технічної роботи. Post-Exploitation охоплює дії всередині скомпрометованої системи. Завершує послідовність Reporting, тобто та фаза, у якій ви зараз перебуваєте, переписуючи цей звіт. Потім для фаз з четвертої по сьому, тобто для Vulnerability Analysis, Exploitation, Post-Exploitation і Reporting, опишіть у одному-двох реченнях, що саме ви робили в межах цього engagement-у. Цей розділ показує клієнтові, що ви не імпровізували і не «гралися», а дотримувалися галузевого стандарту.

Якщо вашим джерелом є Лабораторна 8, фаза Exploitation у вашому випадку це Hydra проти SSH. Якщо джерело Лабораторна 9, фаза Post-Exploitation це робота з SUID і sudo. Прив'язуйте опис фаз до того, що ви реально робили. Загальні формулювання тут не зараховуються.

Частина 4. Технічні знахідки

(30 балів. Трек А)

Це серце звіту. Усе попереднє веде сюди, усе наступне виходить звідси. Мінімальна кількість знахідок дорівнює чотирьом. Кожна знахідка є окремою підсекцією звіту з повною анатомією за Лекцією 10.

Завдання 4.1. Чотири знахідки за PTES-анатомією (24 бали, по 6 балів за знахідку)

Кожна знахідка повинна мати всі вісім полів, перелічені у таблиці нижче. Це розширена звітна структура: вона зберігає логіку анатомії з Лекції 10, але додає Affected Asset, Steps to Reproduce і References для клієнтського PTES-звіту. Знахідка з відсутнім хоча б одним полем оцінюється у половину балів за неї.

Поле	Що повинно бути
Title	Коротка, конкретна назва, без CVE-номера у заголовку. Поганий приклад має вигляд «CVE-2011-2523 vsftpd Backdoor». Хороший приклад натомість виглядає так: «Backdoored vsftpd 2.3.4 service exposes root shell on FTP smiley trigger».
Severity	Категорійна оцінка серйозності за стандартною CVSS-шкалою у діапазоні від Low до Critical. Плюс точне CVSS v3.1 значення з вектором. Плюс обов'язково обґрунтування у двох-трьох реченнях, чому саме така severity у контексті ЦЬОГО клієнта. Орієнтовний приклад: «High (7.5), вектор AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N. Сервер обробляє платежі, тож компрометація читання даних еквівалентна порушенню PCI DSS.» Не копіюйте наведений CVSS-вектор автоматично: він має відповідати саме вашій знахідці, способу експлуатації та контексту клієнта.
Affected Asset	Конкретна система, IP, hostname, версія service. Не «the server». Орієнтовний приклад: «Production server cassandra-prod-01 (10.0.4.12), service vsftpd 2.3.4 on port 21.»
Description	Два-чотири речення прози. Що це за уразливість, як вона виникла (історія backdoor-у, помилка конфігурації, брак контролю), чому вона важлива у контексті цього клієнта. Без копіпасту з NVD.
Steps to Reproduce	Послідовність команд від nmap до отримання shell. Точні команди, точний синтаксис, без скорочень. У разі використання Metasploit вкажіть модуль, опції, payload. У разі ручної експлуатації наведіть точну послідовність символів і запитів.
Evidence	Скріншоти з ВАШОГО запуску. Кожен скріншот має підпис у форматі «Figure N.M: Опис того, що видно на скріншоті». Скріншот без підпису не

Поле	Що повинно бути
	зараховується. Підпис у форматі «скріншот терміналу» оцінюється у половину балів за відповідну знахідку.
Recommendation	Адресна, кількісна, з посиланням на стандарт. Не «update vsftpd». Так: «Замінити vsftpd 2.3.4 на vsftpd 3.0.5 або вище. У разі неможливості upgrade протягом семи днів заблокувати порт 21 на firewall до завершення upgrade. Посилання: CIS Debian Benchmark v3.0, Section 2.2.5.»
References	Перелік довідкових ідентифікаторів, що включає CVE, CWE, OWASP, MITRE ATT&CK technique ID. Мінімально це CVE плюс ATT&CK technique. У випадку vsftpd це виглядає як CVE-2011-2523, CWE-78, MITRE ATT&CK T1190 Exploit Public-Facing Application.

Звідки взяти чотири знахідки, якщо ваша вихідна лабораторна мала менше явних уразливостей? Розкладайте атаківий ланцюг на компоненти. Якщо вашим джерелом є Лабораторна 8 з пароллями, перша знахідка стосується слабкої парольної політики SSH. Друга може фокусуватися на тому, що стандартні облікові дані не було змінено. Третя стосується відсутності rate limiting на боці SSH-сервісу. Четверта може йти у бік слабкої обробки облікових даних на рівні конфігурації клієнта. Якщо ж ваше джерело Лабораторна 9, то перша знахідка природно стосується надмірної SUID-поверхні. Друга описує небезпечне sudoers-правило. Третя зосереджена на відсутності auditd для setuid syscalls. Четверта стосується застарілої версії дистрибутива. Логіка однакова. Атакуючий ланцюг, який ви пройшли руками, можна розкласти на самостійні класи проблем, кожен з яких заслуговує окремого опису.

Severity повинна бути різною. Якщо у вас усі чотири знахідки мають severity High, ви або обрали проблематичну вихідну лабораторну, або ви ще не вмієте належно оцінювати серйозність. Реалістичний розподіл виглядає приблизно так. Одна знахідка Critical чи High. Одна High. Одна Medium. Одна Low або Informational. Такий розподіл відображає реальність більшості тестів. Якщо у вас усі знахідки Critical, перевіряйте обґрунтування ще раз.

Завдання 4.2. Cross-reference attack chain (3 бали)

Після опису всіх знахідок додайте короткий розділ під назвою Attack Chain. У ньому покажіть, як ваші знахідки пов'язані одна з одною у послідовність, що приводить до повної компрометації. Орієнтовний приклад звучить так. «Знахідка №1, тобто слабкий пароль, дає перший shell. Знахідка №2, надмірна SUID-поверхня, відкриває шлях до root. Знахідка №3, відсутність auditd, гарантує, що цей ланцюг не буде помічений під час реальної атаки.» Цей розділ показує клієнтові, що ваші знахідки не є випадковою колекцією, а складають зв'язану історію атаки.

Завдання 4.3. MITRE ATT&CK mapping (3 бали)

Окрема таблиця наприкінці частини 4 містить мапування ваших знахідок на ATT&CK techniques. Колонки таблиці такі. Перша колонка це Finding ID, тобто посилання на конкретну знахідку зі списку вище. Друга колонка позначає ATT&CK Tactic, тобто одну з тактик з матриці. Третя колонка містить Technique ID разом із назвою. У четвертій колонці зазначається Sub-technique у разі його застосування. Це той самий принцип, який ми обговорювали на занятті в Лекції 10. Не вписуйте усі чотирнадцять тактик. Вписуйте лише ті, які реально присутні у вашому атаковому ланцюгу. Без мапування на ATT&CK ваш звіт не буде сприйнято як сучасний. З мапуванням він стає зрозумілим для будь-якого SOC у Європі чи США.

Частина 5. Зведена таблиця рекомендацій

(10 балів. Трек А)

Завдання 5.1. Priority Recommendations Table (5 балів)

Окрема таблиця, що містить усі рекомендації зі знахідок Частини 4, відсортовані за пріоритетом впровадження. Перша колонка це порядковий номер. Друга це сама рекомендація у стислій формі. Третя колонка вказує на severity тієї знахідки, яку закриває рекомендація. Четверта колонка це Effort. Тут передбачені три рівні складності впровадження. Можна позначати рекомендацію як Low, якщо її впровадження не виходить за межі звичайної роботи системного адміністратора. Medium застосовується тоді, коли потрібна координація між кількома командами. High резервується для рекомендацій, що потребують архітектурних змін чи закупівель. П'ята колонка вказує власника, тобто посаду чи відділ з боку клієнта, відповідальний за впровадження. Серед типових власників фігурує адміністратор системи. Поряд з ним відповідальність може лежати на DevOps-команді. Окремо може фігурувати служба безпеки як власник інформаційного ризику. У разі рекомендацій, що потребують закупівлі, власником стає відділ procurement. Пріоритет повинен бути обґрунтований не за CVSS, а за відношенням impact до effort. Перший рядок таблиці це найкраще співвідношення, тобто висока серйозність за низьких зусиль. Останній рядок це навпаки, тобто низька серйозність за високих зусиль.

Завдання 5.2. Найкритичніша одна (5 балів)

Після таблиці подається абзац обсягом чотири-п'ять речень про ту єдину рекомендацію, яку клієнт повинен впровадити перш ніж усе інше. Цей абзац складається з двох частин. Перша частина пояснює, чому саме ця рекомендація має пріоритет. Тут йдеться про те, що змінилося б у ризик-профілі клієнта, якби він впровадив тільки її. Друга частина чесно говорить про ціну, яку платить бізнес за впровадження. Сюди входять реальні незручності для адміністраторів, з якими доведеться рахуватися щодня. Окремо існують ризики поломки workflow на період впровадження. Завершують перелік прямі втрати продуктивності, з якими клієнтові доведеться змиритися протягом перехідного періоду. Без розуміння ціни рекомендація звучить як вимога. З розумінням ціни вона звучить як професійна порада, яку клієнт може реально розглянути. За структурою цей абзац є точною копією

того, що ви вже робили у Завданні 3.5.2 Лабораторної 9, але тепер ви робите його для всього engagement-у, а не для одного класу проблем.

Частина 6. Додатки і докази ітерації

(5 балів. Трек А)

Завдання 6.1. Tools used (1 бал)

У Додатку А подається список усіх інструментів з зазначенням версій. У моєму досвіді клієнт може попросити цю інформацію для відтворення тесту або для compliance-аудиту, тож ця сторінка не є косметичною. Один рядок таблиці на інструмент. Перша колонка містить назву інструмента. Друга колонка вказує конкретну версію, з якою ви працювали. Третя колонка пояснює призначення інструмента в межах вашого engagement-у. Орієнтовний рядок виглядає так. «Nmap | 7.94 | Виявлення активних хостів і відкритих портів на цільовій підмережі.»

Завдання 6.2. References (1 бал)

Додаток В містить перелік усіх зовнішніх посилань, до яких звертається текст звіту. Серед типових категорій тут фігурують записи з NVD на конкретні CVE. Поряд із ними звичайно згадуються CIS Benchmarks для відповідної версії дистрибутива. OWASP-матеріали входять у перелік тоді, коли ви посилаєтеся на проєктні стандарти безпеки веб-додатків. MITRE ATT&CK увійде сюди обов'язково, оскільки ваше мапування з Частини 4 спирається саме на цей фреймворк. GTF0Bins з'являється у переліку у тих випадках, коли ви описували SUID-знахідку чи sudo-misconfiguration. Формат запису такий. Спочатку йде нумерований ідентифікатор. Поряд з ним подається повний URL посилання. Закриває запис дата останнього доступу до джерела. Якщо посилання у звіті немає, посилання у Додатку В теж немає. Усі посилання Додатка В мають з'являтися у тексті звіту.

Завдання 6.3. Iteration evidence (3 бали)

Додаток С найважливіший з трьох. Тут ви наводите внутрішні артефакти ітерації, тобто докази того, що звіт пройшов через ваше особисте редагування. Можна обрати один із трьох варіантів. У першому варіанті ви наводите ваш перший варіант оцінки CVSS для однієї зі знахідок із тих самих векторних компонентів, фінальне значення з обґрунтуванням, а також пояснення, що саме у контексті клієнта змусило вас перерахувати оцінку. У другому варіанті ви показуєте першу версію Executive Summary і фінальну, з підкресленням ключової зміни і поясненням, чому фінальна сильніша. У третьому варіанті ви наводите перелік ваших трьох найскладніших рішень при написанні звіту з коротким обґрунтуванням кожного.

Цей додаток одночасно є анти-AI-маркером. Згенерований звіт не має слідів ітерації, бо генерація відбувається миттєво. Реальний звіт ітерації має. Ваше завдання у цьому додатку показати слід вашого власного мислення.

ПЕРЕХІД ДО ТРЕКУ В

Якщо ви завершили Частини 1-6 і отримали валідні результати, у вас уже повний бал за Треком А, тобто 75 зі 100. Решта документа це Частина 7, тобто Трек В, розширення на 25 балів для оцінки А або А мінус. Трек В це додаток до основного звіту під назвою Remediation Roadmap. Його завдання перетворити ваші знахідки на план виконання, що читається CIO.

Перш ніж починати Трек В, переконайтеся, що Частини 1-6 закінчені і вичитані. Слабкий Трек А з сильним Треком В залишається слабким звітом. Сильний Трек А без Треку В вже є повноцінним deliverable. Якщо ви плануєте здавати лише Трек А, пропустіть наступний розділ і переходьте одразу до підрозділу «Що здавати».

Частина 7. Remediation Roadmap

(25 балів. Трек В)

Технічний звіт описує знахідки. Roadmap описує, що з ними робити, у якому порядку, кому і за скільки. У реальному engagement-і Roadmap нерідко оплачується окремо від основного звіту, бо клієнти готові платити більше за документ, що реально допомагає планувати. Цей розділ є вашим першим досвідом виходу за межі формули «знайти і описати» у напрямку «допомогти впровадити».

Завдання 7.1. Priority Matrix (8 балів)

Класична 2x2 матриця Effort × Impact. По осі Х йдуть зусилля впровадження у вигляді категорій Low і High. По осі Y йде бізнес-impact від виправлення, теж у двох категоріях. Усі ваші рекомендації з Частини 5 розміщуються у відповідних квадрантах. Квадрант High Impact, Low Effort відомий під назвою Quick Wins. Це перші кандидати на впровадження. Квадрант Low Impact, High Effort відомий під назвою Deprioritize, навіть якщо знахідка має високу CVSS.

Намалюйте матрицю у Word через Insert → Shapes, або вставте її скріншотом з Excel. Обидва варіанти прийнятні. Кожна рекомендація позначається своїм номером з Частини 5. Під матрицею розмістіть короткий абзац обсягом три-чотири речення, що пояснює рішення про розподіл, з акцентом на квадрант Quick Wins.

Завдання 7.2. Cost Estimates per Finding (7 балів)

Таблиця з оцінкою вартості впровадження для кожної рекомендації. Структура колонок така. Перша колонка це номер рекомендації. Друга це сама рекомендація у стислій формі. Третя колонка має назву Engineering Effort і виражає вартість у людино-годинах. Четверта колонка має назву External Cost і виражає зовнішні витрати у доларах США або у тенге. Зовнішні витрати з'являються у тих випадках, коли рекомендація потребує закупівлі. Типовим прикладом тут є придбання MFA-токенів для посилення автентифікації. Поряд із цим часто фігурує модернізація firewall-конфігурації або заміна обладнання. Ліцензія на enterprise-рівень SIEM також належить до класичних прикладів зовнішніх витрат у пентест-roadmap. П'ята колонка це Total Cost Estimate, тобто загальна оцінка вартості впровадження. Шоста колонка має назву Confidence і виражає вашу впевненість в оцінці.

Тут передбачено три рівні. Низький рівень впевненості застосовується тоді, коли оцінку зроблено за дуже обмеженими даними. Середній рівень відповідає випадкам, у яких ви маєте аналог з минулої практики. Високий рівень резервується для тих випадків, коли вартість роботи відома вам із прямого досвіду.

Не вигадуйте цифри. Для людино-годин оцінюйте з огляду на те, скільки часу зайняла би у вас ця робота у реалістичних умовах. Заміна паролів адміністратора це приблизно дві години роботи. Сюди входить написання скрипта. Поряд з цим іде оголошення change window для команди. Сама виконавча частина займає менше години. Впровадження auditd-правил вимагатиме від восьми до шістнадцяти годин. Окремо йде написання правил. Окремо тестування у середовищі dev. Завершує роботу деплой у production з усіма ризиками і відкатом, якщо щось піде не так. Для зовнішніх витрат користуйтеся порядком величини, не точними значеннями. Запис «від п'яти до п'ятнадцяти тисяч доларів за річну ліцензію enterprise SIEM» чесніший, ніж довільне «\$8 750».

Якщо точна ціна невідома, використовуйте діапазон і коротко пояснюйте припущення. Наприклад: «8-16 людино-годин, припущення: один системний адміністратор, одне dev/test-середовище і одне production-вікно для впровадження».

Завдання 7.3. 30/60/90 Day Plan (8 балів)

Розподіл ваших рекомендацій за часовими вікнами впровадження. У перші тридцять днів потрапляють Quick Wins з матриці, тобто рекомендації з найвищим співвідношенням impact до effort, ті, що не вимагають закупівель чи інфраструктурних змін. У вікно з тридцять першого по шістдесятій день потрапляють рекомендації середньої складності, які потребують координації між командами або невеликих закупівель. У вікно з шістдесят першого по дев'яностий день потрапляють рекомендації, що вимагають значно більших ресурсів. Сюди належать архітектурні зміни. Поряд із ними у це вікно потрапляють тендерні процедури на закупівлю. Завершують перелік заходи з навчання персоналу, оскільки вони потребують часу на підготовку матеріалів і організацію сесій. Для кожного з трьох вікон оформіть таблицю. У ній зазначаються номери рекомендацій з Частини 5. Окремою колонкою йде відповідальна сторона з боку клієнта. Третій елемент таблиці це milestone у вигляді конкретної події, що означатиме завершення впровадження. Закриває таблицю success metric, тобто кількісний показник, за яким можна перевірити, чи рекомендацію реально впроваджено.

Найчастіша помилка junior-пентестерів у цій секції це рівномірний розподіл, тобто третина рекомендацій у кожне з трьох вікон. Реалістична картина асиметрична. Більшість Quick Wins припадає на перші тридцять днів. Найскладніше припадає на дні з шістдесят першого по дев'яностий. У середньому періоді перебувають заходи, що потребують узгодження між кількома відділами.

Завдання 7.4. Risk Register Entry (2 бали)

Останній артефакт Треку В це формальний запис у Risk Register у форматі, який зрозуміє рада директорів. Один запис на найкритичнішу знахідку. Колонки запису такі. Risk ID у форматі RISK-2026-001. Risk Description обсягом одне речення. Inherent Risk у формі категорійної оцінки, що подається

без урахування mitigation. Current Controls, тобто перелік того, що вже є у клієнта. Residual Risk з огляду на наявні контролі. Recommended Treatment, тобто рекомендована стратегія роботи з ризиком. Тут передбачено чотири стандартні варіанти. Ризик можна прийняти, якщо вартість мітигації перевищує потенційні збитки. Альтернативно ризик можна мітигувати через впровадження контролів. Третій варіант це перенести ризик на іншу сторону, наприклад через страхування чи аутсорсинг. Останній варіант це уникнути ризику взагалі через відмову від відповідного бізнес-процесу. Поряд із цим зазначається owner, тобто відповідальна особа з боку клієнта, і review date, тобто дата наступного перегляду запису.

Risk Register — це документ governance, а не суто security-документ. Тон тут має бути нейтральним, формулювання недраматичними. «Risk of unauthorized access to payment processing infrastructure due to weak authentication controls» це добрий приклад. «CRITICAL VULNERABILITY ALLOWS HACKERS TO STEAL ALL DATA» це поганий приклад, навіть якщо технічно це правда. Корпоративний governance не оперує у форматі панічних формулювань.

Що здавати

Єдиний файл звіту у форматі DOCX. Назва файлу має відповідати шаблону Lab13_Прізвище_Група.docx. Орієнтовний приклад це Lab13_Журавель_SIS-2026.docx. На cover page вкажіть рядок «Виконано: Трек А» або «Виконано: Трек А + Трек В» залежно від обсягу виконаної роботи.

Орієнтовний обсяг власного тексту складає від двох із половиною до трьох з половиною тисяч слів для Треку А без додатків. У разі виконання Треку В додаються ще від тисячі до півтори тисячі слів. Звіт, що не досягає мінімального обсягу для Треку А, тобто двох із половиною тисяч слів, оцінюється за нижньою межею для кожного розділу. Звіт, що перевищує максимальний обсяг у вісімнадцять сторінок без додатків, втрачає бали за невідповідність вимогам клієнта, який просив від дванадцяти до вісімнадцяти сторінок.

Мінімально прийнятний звіт має містити 4 повні знахідки, але якість доказів і обґрунтування важливіші за кількість тексту. Не збільшуйте обсяг штучно: порожні абзаци, повтори і загальні фрази знижують професійну якість звіту.

Скріншоти у звіті повинні бути ВАШИМИ, тобто з ВАШОЇ роботи у відповідній лабораторній, а саме у Лабораторній 7, 8 чи 9. Якщо ви загубили скріншоти зі своєї попередньої роботи, тоді переробіть атаку у тій самій VM і зробіть нові. Скріншоти з інших джерел автоматично знижують оцінку до нуля за відповідну знахідку. Маю на увазі статті з Wikipedia, що подають загальний опис уразливості. Сюди ж належать публікації на Medium, написані іншими дослідниками. GitHub-walkthrough-и того ж класу проблем теж потрапляють у цю заборону. Винятків не передбачено.

Звіт буде оцінено за рубрикою з п'яти критеріїв, у тому ж форматі, що й попередні лабораторні роботи. Перший критерій це Виконання, тобто власне ступінь опрацювання матеріалу. Другий критерій це Технічна коректність, тобто точність формулювань і правильність використання термінології. Третій критерій присвячений Якості доказів, серед яких ключову роль грають скріншоти і коректність їхніх підписів. Четвертий критерій оцінює Розуміння, тобто здатність

студента пояснити, чому саме така severity, чому саме така рекомендація, чому саме такий пріоритет. П'ятий критерій це Повнота охоплення поставленої задачі. Кожен з критеріїв оцінюється у 20 балів. Окремо буде відмічено рівень виконання Треку А у діапазоні від В мінус до А. Окремо також фіксується наявність повного Треку В з можливими додатковими балами у трьох діапазонах. Кінцевий термін відповідає графіку цього тижня. Здача відбувається до встановленого дедлайну. Питання, що виникають у процесі роботи, доцільно ставити у Teams або під час офіс-годин, а не у день, що передує здачі.

Це остання робота семестру. Перетворіть ваш найсильніший лабораторний результат на документ, який ви зможете показати на першому ж серйозному інтерв'ю у галузі. Бажаю успіху.